

Date: DECEMBER 28,2022	Entry: 2
Description	Review of a incident involving unauthorized access to the customer PII Exposed by a bug using web application vulnerabilities
Tool(s) used	List any cybersecurity tools that were used. Web application access logs and server logs
The 5 W's	Capture the 5 W's of an incident. Who caused the incident? An external, unknown threat actor who sent ransom emails demanding cryptocurrency payment. What happened? The attacker exploited a forced browsing vulnerability in the e-commerce web application. By modifying order numbers in the URL, they accessed ~50,000 customer purchase confirmation pages and exfiltrated PII and financial data. When did The attack likely started before December 22, 2022 (first ransom email). It was officially discovered on December 28, 2022 at 7:20 p.m. PT. the incident occur? Where did the incident happen? In the organization's e-commerce web application — specifically the purchase confirmation page URL parameter. Why did the incident happen? The web application lacked proper access controls. It did not verify whether users were authenticated before displaying order confirmation pages, allowing anyone to enumerate order numbers freely.
Additional notes	The first ransom email on December 22 was deleted by the employee

	assuming it was spam — this delayed detection by 6 days. Earlier escalation could have reduced the impact significantly. Recommendations include penetration testing, URL allowlisting, and enforcing authentication.
--	---